AWS 클라우드 웹 서비스 아키텍처 다이어그램 (ap-northeast-2 서울 리전)

화살표 색상 범례: [초록 화살표 ——▶] INBOUND 허용 트래픽 (외부->EC2) | [하늘 화살표 ◀——] OUTBOUND 응답/외부통신 (EC2->외부) | [빨강 [X]] NACL/SG 차단(0-65535 전체개방 금지)

[EXTERNAL] 외부 인터넷 요청

[WEB] 일반 웹 사용자 (Browser / Client)

- 방식 (A): http://43.201.142.88/
- 방식 (B): GET http://43.201.142.88/health
- INBOUND 허용: 0.0.0.0/0 -> TCP 80 (초록 화살표)

[SSH] 학습자 관리자 PC (Admin)

- 접속: ssh -i key.pem ubuntu@43.201.142.88
- INBOUND 제한: 211.234.118.42/32 (내 공인 IP만)
- [X] 타 공인 IP / 0.0.0.0/0 SSH 접근 시 SG에서 DROP 차단

[IGW] Internet Gateway

Name: codyssey-igw
ID: igw-0a1b2c3d4e5f60001

- IN : 43.201.142.88 -> 10.0.1.24
- OUT: 10.0.1.24 -> 43.201.142.88
- VPC 외부 인터넷 1:1 NAT 관문

[AWS Region] ap-northeast-2 (Seoul) | [VPC] codyssey-vpc (10.0.0.0/16)

VPC ID: vpc-01122334455667788 (DNS Hostnames: Enabled / 논리적으로 격리된 가상 네트워크)

[Route Table] codyssey-public-rt (rtb-0123456789abcdef0)

- 명시적 서브넷 연결(Association): codyssey-public-subnet (10.0.1.0/24) [State: associated]

Destination: 10.0.0.0/16 -> Target: local [State: active] (VPC 내부 통신)
Destination: 0.0.0.0/0 -> Target: igw-0a1b2c3d4e5f60001 [State: active] (인터넷 인·아웃바운드)

[Public Subnet] codyssey-public-subnet (10.0.1.0/24 | AZ: 2a | subnet-0fedcba9876543210)

[1차 방화벽: Network ACL (Stateless)] ——▶ INBOUND #100 ALLOW (TCP 80, 22, Ephemeral 1024-65535) | [X] Rule * DENY
◀—— OUTBOUND #100 ALLOW (0.0.0.0/0 All Traffic 응답 및 외부 통신) | Stateless 양방향 개별 검사

[2차 방화벽: Security Group (Stateful)] codyssey-web-sg (sg-08c9d1e2f3a4b5678)

- ——▶ SG INBOUND (허용): [HTTP] TCP 80 <- 0.0.0.0/0 (전체) | [SSH] TCP 22 <- 211.234.118.42/32 (내 공인 IP 단독 허용)
- [X] SG INBOUND (차단): 0.0.0.0/0 전체 포트(0-65535) 개방 규칙 생성 금지 & 지정되지 않은 모든 포트 암묵적 DENY 차단
- ◀—— SG OUTBOUND (허용): All Traffic -> 0.0.0.0/0 (Stateful 응답 자동 허용 + APT/Docker 설치 및 curl example.com 통신)

[EC2 Instance] codyssey-web-ec2 (i-0f8a92b1c4d5e6789) | Public IP: 43.201.142.88

★ 주소/사양: Public IP = 43.201.142.88 | Private IP = 10.0.1.24 | Spec: t3.micro (Ubuntu 24.04, EBS 8GiB gp3)

[Web Server] Nginx & Docker 컨테이너

- 이미지명: codyssey-web:latest
- 포트 매핑: 0.0.0.0:80 -> 80/tcp (-p 80:80)
- GET / -> 200 OK (Hello Cloud)
- GET /health -> 200 OK ("OK" 기본 헬스체크)
- [보너스 1] Let's Encrypt HTTPS(443)
- [보너스 2] Docker 컨테이너 배포 완료
- [운영 권장] /health를 ALB 기본 헬스체크로 사용

[Verification] 통신 검증 (UTC 타임스탬프 동기화)

- 검증 시각: 2026-11-10T05:32:10Z (UTC)
1) 내부 응답: curl -i http://localhost -> 200 OK
2) 외부 헬스체크 원본 로그 (curl-health-check.log):
curl -i http://43.201.142.88/health -> 200 OK
3) 아웃바운드: curl -I https://example.com -> 200
4) 리소스 역순 정리 (Retry 1건 성공, 잔여 0건, $0.00)
로그: docs/logs/cleanup-execution.log

[IAM] 최소권한 거버넌스 & [방화벽 비교] NACL vs Security Group

IAM 사용자: codyssey-cloud-user | EC2 IAM Role | 90일 정기 재평가

- 정책: iam/least-privilege-policy.json (서울 리전 ap-northeast-2 Condition)
- 허용: EC2 · VPC · Subnet · IGW · RouteTable · SG 필수 작업만 허용
- 명시적 거부(Explicit Deny): S3, RDS, IAM 등 무관 서비스 차단 (No Admin)
- JIT 임시 권한: STS AssumeRole(1시간 만료) & 90일 주기 권한 재검토/키 교체
- 표준 태그: Name / Project=codyssey-cloud / Owner / Env=dev / CostCenter

[방화벽 핵심 차이] Network ACL (Stateless) vs Security Group (Stateful)

1) Network ACL (서브넷 경계 1차 방화벽 | Stateless 비상태 검사):

- 들어올 때(Inbound #100 ALLOW)와 나갈 때(Outbound #100 ALLOW)를 각각 별도 검사
- 명시적 DENY 규칙 지원 (특정 공격자 IP 서브넷 진입 자체 차단 가능)

2) Security Group (EC2 ENI 경계 2차 방화벽 | Stateful 상태 저장 검사):

- INBOUND 허용(80 전체, 22 내 IP) 통과 시, 응답 OUTBOUND는 상태 테이블로 자동 허용!
- 허용(Allow) 규칙만 지정 가능 (기본값: 명시되지 않은 모든 포트는 암묵적 DENY 차단)

3) [확장/ALB & Auto Scaling 지침 (평가 항목 #16)]:

- ALB 도입 시 SG 체이닝: Internet -> ALB-SG(80/443) -> EC2-SG(80 소스를 ALB-SG로만 제한)
- Auto Scaling 권장 임계치: CPU > 70% 5분 지속 시 Scale-Out (Min=1, Desired=2, Max=4)
- 프라이빗 서브넷 확장 시: 아웃바운드 필요 시 NAT Gateway 연결 / 순수 DB는 local만 유지

[트래픽 흐름 및 방화벽(NACL·SG) 통과 요약] (증빙 시각: 2026-11-10T05:32:10Z UTC)

[초록 화살표 ——▶ INBOUND 요청] 외부 클라이언트(80/22) ——▶ IGW(NAT) ——▶ Route Table(local) ——▶ NACL(Inbound #100 Allow) ——▶ SG(Inbound 80 전체 / 22 내 IP Allow) ——▶ EC2(:80)

[하늘 화살표 ◀—— OUTBOUND 응답] EC2(10.0.1.24) ——▶ SG(Stateful 응답/Outbound Allow) ——▶ NACL(Outbound #100 Allow) ——▶ Route Table(0.0.0.0/0->IGW) ——▶ IGW(43.201.142.88) ——▶ 외부

[빨강 표시 [X] 차단(DROP)] 비인가 포트(0-65535 전체 개방 금지) 및 타 IP의 SSH(22) 접근 시 Security Group Inbound 단계에서 즉시 패킷 DROP (Connection timed out)